

Informática Forense

1. Metodologías DEFR

PRESENTADO POR:
David Santo Orcero

ENTIDAD
Perito judicial

MÓDULO
Avanzado

MODIFICAR EL ORIGINAL



GOLPE DE REMO

EL PROBLEMA



La naturaleza del problema

- Han “entrado” en los sistemas.
- Queremos identificar y que se castigue al culpable.
- **No somos policías.** Hay muchas cosas que ni debemos hacer, ni podemos hacer legalmente.
- Normalmente se estudian metodologías DFIR como respuestas a incidentes, y suelen ser las políticas de los SOC. ¿Son las únicas alternativas posibles? ¿Son las mejores en todas las circunstancias?

DFIR





Definición

Definición

DFIR, *Digital Forensics and Incident Response*, es un campo especializado en la ciberseguridad enfocado en identificar, investigar y responder a incidentes de seguridad informática. Incluye la contención, erradicación, recuperación y comunicación del incidente.

- ¿Incluye la recolección de evidencias forenses de cara a un juicio?
- ¿Realmente van a poder ser aceptadas por el tribunal que tome conocimiento de la causa?



Definición

Definición

DFIR, *Digital Forensics and Incident Response*, es un campo especializado en la ciberseguridad enfocado en identificar, investigar y responder a incidentes de seguridad informática. Incluye la contención, erradicación, recuperación y comunicación del incidente.

- ¿Incluye la recolección de evidencias forenses de cara a un juicio?
- ¿Realmente van a poder ser aceptadas por el tribunal que tome conocimiento de la causa?



Respuesta a Incidentes

La Respuesta a Incidentes se enfoca en:

- Contención del incidente para prevenir más daños.
- Erradicación de la amenaza y recuperación de sistemas.
- Restauración de operaciones normales.
- Comunicación con partes interesadas y autoridades.



Identificación de la Causa Raíz

Una tarea crítica en DFIR es identificar cómo y por qué ocurrió el incidente. Esto incluye:

- Determinar vulnerabilidades explotadas y tácticas utilizadas.
- Identificar fallas en políticas o procedimientos de seguridad.
- Utilizar esta información para mejorar las medidas de seguridad.



Ejemplos de metodologías DFIR

- SANS Incident Response Process
- ISO/IEC 27035
- FIRST Standards
- CERT Model
- PICERL
- Diamond Model
- Cyber Kill Chain

DEFR





Definición

Definición

DEFR *Digital Evidence First Responder* es la primera etapa del análisis de la evidencia digital. Corresponde con las funciones derivadas de ser el primer interviniente ante un delito tecnológico: identificar y preservar las evidencias digitales, garantizando su mismidad y un futuro derecho a la igualdad de armas y a la contrastabilidad de las deducciones realizadas.

- ¿Incluye la contención, erradicación, recuperación y comunicación del incidente?
- ¿Prioriza esto a la preservación de la prueba, o la preservación de la prueba a cualquier otro criterio?



Definición

Definición

DEFR *Digital Evidence First Responder* es la primera etapa del análisis de la evidencia digital. Corresponde con las funciones derivadas de ser el primer interviniente ante un delito tecnológico: identificar y preservar las evidencias digitales, garantizando su misinidad y un futuro derecho a la igualdad de armas y a la contrastabilidad de las deducciones realizadas.

- ¿Incluye la contención, erradicación, recuperación y comunicación del incidente?
- ¿Prioriza esto a la preservación de la prueba, o la preservación de la prueba a cualquier otro criterio?



La primera intervención

La primera intervención ante un delito informático se enfoca en:

- Preservar la evidencia digital.
- Asegurar su mismidad, y que será indisputable metodológicamente el proceso de recogida, almacenamiento y transporte de cara a un tribunal.



Preservación de la evidencia

El DEFR tiene como objetivo principal la preservación de la evidencia de forma indisputable. Esto incluye:

- Estar legalmente habilitado para poder ejercer las funciones de DEFR en tu jurisdicción.
- Seguir el más alto nivel de exigencia y de rigor metodológico en todos los pasos.
- Una documentación exhaustiva de los pasos.
- Ser el inicio de la cadena de custodia.



Ejemplos de metodologías DEFR

- Siempre, y con preferencia absoluta, las metodologías, reglamentaciones e instrucciones internas del organismo en base al que se interviene como primer interviniente y que acredita a hacerlo.
- Metodologías y directrices INTERPOL y EUROPOL.
- Metodologías y directrices del NIST (National Institute of Standard and Technology) específicas para forense.
- Metodologías y directrices descrita por las guías NIJ del departamento de Justicia de EEUU.
- Norma UNE: 197010, UNE-EN ISO/IEC 27037.

DFIR vs DEFR



DEFR vs DFIR en Respuestas a Incidentes

A mi me comienzan a parecer muy distintas las metodologías y los perfiles. . .



Digital Evidence First Responder (DEFR)

- **Foco Principal:** Recolectar y preservar evidencia digital al inicio de una investigación forense.
- **Actividades:**
 - Identificación de fuentes de evidencia digital.
 - Recolección segura y preservación de evidencia.
 - Documentación detallada de acciones y condiciones.
- **Perfil del Respondedor:** Según jurisdicción y orden del derecho, el perfil formativo y profesional recogido en el marco legal. Con profundo conocimiento metodológico y del contexto legal, centrado en la preservación de la evidencia y la documentación del proceso.



Digital Forensics and Incident Response (DFIR)

- **Foco Principal:** Responder a incidentes minimizando el impacto del incidente, y favoreciendo una recuperación lo más temprana posible.
- **Actividades:**
 - Análisis detallado de la evidencia digital.
 - Manejo del incidente, mitigación de daños y recuperación.
 - Comunicación con partes interesadas y autoridades.
- **Perfil del Respondedor:** Gran formación técnica en sistemas, en seguridad informática, en herramientas de ataque y defensa, en gestión de incidentes y con capacidad natural de toma de decisiones bajo presión.



Comparación y Complementariedad

- DEFR se centra en preservar la prueba para su posterior judicialización.
- DFIR se centra en la respuesta al incidente para reducir el impacto en la empresa.
- Ambos enfoques son fundamentales y complementarios en la ciberseguridad.
- Equipos mixtos.
- Distintas metodologías.

METODOLOGÍAS DEFR



El RFC 3227

Qué es

- “Abuelo” de las metodologías.
- Insiste en la firma hash.
- Insiste en hacer copia bit a bit, y no trabajar sobre esa copia.



El RFC 3227

Qué hay que documentar adicionalmente

- Dónde, cuándo y por quién la evidencia fue descubierta y recogida.
- Dónde, cuándo y por quién la evidencia fue manejada o examinada.
- Quién ha tenido la custodia de la evidencia, y durante qué periodo. Cómo fue almacenada.
- Cuándo la evidencia cambió de custodio, cuándo y cómo ocurrió la transferencia (incluyendo números de envío, etc)



Metodologías NIST

Qué es

- El NIST es el National Institute of Standards and Technology.
- Incluye una serie de guías que son seguidas por profesionales de la seguridad externos a las respectivas FCSE.



Metodologías NIST

Documentos de pertinencia en NIST

- Computer Security Incident handling guide. Publicación especial 800-61 Revisión 2 del 2012.
- Guide to integrating forensic techniques into incident response. Publicación especial 800-86 del 2006.
- Guidelines on Mobile Device Forensics. Publicación especial 800-101 revisión 1 del 2014.



Metodologías NIST

Guía NIST para integrar técnicas forenses en respuestas a incidentes

- *Computer Security Incident handling guide*: guía de gestión de las intrusiones, muy seguida por los especialistas en la seguridad, pero que no hace mención implícita o explícita a la recogida de pruebas.
- Framework previo, importante lectura.



Metodologías NIST

Guía NIST para integrar técnicas forenses en respuestas a incidentes

- Documento *Guide to integrating forensic techniques into incident response* es una guía complementaria a la anterior, que tiene como objetivo coordinar la actividad de los técnicos especializados –en España serían los peritos no pertenecientes a las FSCE– con el sistema de justicia.
- Documento muy técnico.



Metodologías NIST

Guía NIST para análisis forense de dispositivos móviles

- Documento *Guidelines on Mobile Device Forensics*: cubre metodológicamente cómo analizar los dispositivos móviles.
- Documento muy técnico.



Metodologías NIJ

Qué son

- El NIJ corresponde con el National Institute of Justice de EEUU –Instituto Nacional de Justicia–.
- Enfocadas al uso por las FCSE (a diferencia de NIST)
- Segregan la figura del First Responder, y del analista forense.



Metodologías NIJ

Metodología NIJ para responsables de la primera intervención

- Documento “Electronic Crime Scene Investigation: A Guide for First Responders”
- Procesamiento escena del delito, extracción de evidencia digital, preservación de evidencia digital.



Metodologías NIJ

Metodología NIJ para el examen forense por las FCSE

- Documento “Forensic Examination of Digital Evidence: A Guide for Law Enforcement”
- Enfocada en el trabajo forense que sigue después de la primera respuesta, es decir, cuando ya se ha hecho el trabajo de preservación.



Normal UNE-EN 27037:2016

Qué es

- Norma sobre las “Directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas.”.
- La norma UNE de redacción de informes periciales TIC requiere su cumplimiento.
- Terminológica y conceptualmente muy clara, no contradice las metodologías NIJ ni las NIST.

METODOLOGÍAS DEFR



SANS Incident Response Process

- Desarrollado por el SANS Institute.
- Se enfoca en seis fases clave: preparación, identificación, contención, erradicación, recuperación, lecciones aprendidas.
- Popular entre profesionales de seguridad informática.



ISO/IEC 27035

- Norma internacional para la gestión de incidentes de seguridad de la información.
- Abarca principios y procesos para el diseño e implementación de respuesta a incidentes.



FIRST Standards

- Desarrollado por el Forum of Incident Response and Security Teams.
- Ofrece estándares y mejores prácticas para equipos de respuesta a incidentes.
- Enfocado en cooperación y coordinación efectiva entre distintas organizaciones y equipos.



CERT Model

- Desarrollado por el CERT Coordination Center.
- Provee procedimientos para establecer y operar un equipo de respuesta a emergencias informáticas.
- Enfocado en preparación, detección, respuesta y recuperación de incidentes.



PICERL

- Variación del modelo de respuesta a incidentes.
- Añade énfasis en la preparación y las lecciones aprendidas.
- Proporciona un enfoque cíclico y evolutivo para la mejora continua.



The Diamond Model of Intrusion Analysis

- Modelo para el análisis de intrusiones cibernéticas.
- Se centra en la comprensión de las relaciones entre adversarios, capacidades, infraestructura y víctimas.
- Útil para análisis de amenazas avanzadas y persistentes.



Cyber Kill Chain

- Desarrollado por Lockheed Martin.
- Describe las etapas de un ataque cibernético.
- Proporciona una estructura para identificar y prevenir intrusiones cibernéticas.

PLANTEAMIENTO METODOLÓGICO DE TRABAJO FORENSE



Principios rectores UNE-EN ISO/IEC 27037:2016

- Relevancia.
- Fiabilidad.
- Suficiencia.
- (Añadido UNE 197010) Oportunidad.

Todo esto incide sobre el la contrastabilidad de las pruebas y el principio de contradicción.



Principios rectores UNE-EN ISO/IEC 27037:2016

Relevancia

La Relevancia es la característica o propiedad que resalta unas evidencias sobre otras debido a su transcendencia, el valor que aporta en el informe pericial. Un informe pericial tendría que poder demostrar la elección de unas evidencias digitales frente a otras para responder al objeto del informe.



Principios rectores UNE-EN ISO/IEC 27037:2016

Fiabilidad

La Fiabilidad se refiere a obtener en un proceso los mismos resultados de forma consistente utilizando los mismos datos de partida y condiciones de contorno. Enunciado de otra forma, se puede reproducir los resultados del proceso de forma consistente con investigadores independientes obteniendo las mismas evidencias, además el procedimiento de la obtención de las evidencias puede ser auditado de forma independiente.



Principios rectores UNE-EN ISO/IEC 27037:2016

Suficiencia

La Suficiencia se refiere a la demostración que la evidencia presentada es representativa, acorde y proporcionada con el objeto del informe pericial. La suficiencia es una característica que tendrá que valorar el autor del informe para cada caso en concreto.



Principio rector añadido a estos por UNE 197010:2015

Oportunidad

La Oportunidad hace referencia al momento temporal y las circunstancias en la que se presenta la evidencia como prueba, puede tener transcendencia en un procedimiento judicial (momento procesal adecuado)



INTERPOL y EUROPOL

“Decomiso de pruebas electrónicas” 2.2 Integridad de los datos

Principio: Ninguna acción llevada a cabo por los organismos encargados de la aplicación de la ley o sus funcionarios deberá modificar los dispositivos o soportes electrónicos que posteriormente puedan servir como pruebas ante los tribunales. Cuando se manejen dispositivos y datos electrónicos, no deben modificarse ni en los equipos ni en los programas. El funcionario encargado es responsable de la integridad del material encontrado en el lugar de los hechos y, por lo tanto, del inicio de la cadena de custodia forense.



INTERPOL y EUROPOL

“Decomiso de pruebas elec.” 2.3 Registro de auditoría

Principio: Cuando se manejen pruebas electrónicas, se deberá crear y conservar un registro de auditoría o de otro tipo para dejar constancia de todas las acciones que se han llevado a cabo con las pruebas electrónicas. Una tercera persona de carácter independiente debería poder estudiar esas acciones y conseguir con ellas el mismo resultado. . .



INTERPOL y EUROPOL

“Decomiso de pruebas elec.” 2.3 Registro de auditoría

... Con el fin de garantizar la validez de las pruebas ante los tribunales, es imperativo que se registren fielmente todas las actividades para permitir que un tercero reconstruya las acciones de las primeras personas que acudieron al lugar de los hechos. Todas las actividades relacionadas con el decomiso, el acceso, el almacenamiento o la transferencia de las pruebas electrónicas deben documentarse exhaustivamente y dicha documentación debe conservarse y mantenerse disponible para su estudio.



Elementos comunes en las metodologías

Unanimidad en...

- Las pruebas forenses no se realizan directamente sobre los dispositivos originales, y un principio rector del proceso de la cadena de custodia es la preservación de la prueba inalterada.
- Uso de la firma hash como herramienta para asegurar que la prueba permanece inalterada.



Elementos comunes en las metodologías

Pasos en la mecánica de trabajo DEFR

- Firmado, en la medida de lo posible, del medio original.
- Clonado o volcado del medio físico a un volcado original.
- Firmado del volcado original.
- Con el volcado y la firma, la primera intervención está terminada, y la mecánica de preservación, asegurada.
- Ese volcado original se gestiona como el mismo original, y jamás se trabaja directamente sobre el volcado original, sino sobre las copias.



Pasos en la mecánica de trabajo DEFR

Firmado del medio original

- No siempre es posible (nube, discos duros de estado sólido, discos con sectores dañados. . .)
- Si se puede hacer, se debe hacer.
- Si no se puede hacer, se debe documentar porqué no se hace.



Pasos en la mecánica de trabajo DEFR

Clonado o volcado del medio físico a un volcado original

- En la medida de lo posible, bit a bit y de la totalidad de la evidencia.
- No siempre es posible hacerlo bit a bit y de la totalidad de la evidencia (cloud, terminales móviles, sectores dañados, NAS)
- Cuando no es posible, se debe documentar porqué no ha sido posible, y qué parte de la evidencia no se ha volcado.



Pasos en la mecánica de trabajo DEFR

Firmado del volcado original

- Marca el instante de tiempo a partir del cual podemos asegurar que la prueba no se ha alterado.
- Da certeza matemática indiscutible de que la evidencia no ha sido alterada en ninguno de sus pasos.
- Debe documentarse de forma exacta cuándo se realiza la firma –fecha y hora–, quién la realiza, cómo la realiza, y en presencia de quién.



Pasos en la mecánica de trabajo DEFR

Se trabaja sobre copias, no sobre originales.

A diferencia de otras áreas de la ciencia forense, dónde siempre se trabaja con originales y el trabajo sobre copias es una mala praxis porque en el proceso de copia se degrada la prueba —cuando la copia es posible— en ingeniería informática se puede obtener copia literal del original del volcado. **La lex artis de la informática forense es preservar el volcado original, y realizar cualesquier pruebas forenses que se fueran a realizar sobre la copia idéntica del volcado original, para evitar que por accidente se altere la prueba.**



Metodologías NIJ

Directrices para responsables de la 1ª respuesta 1/4

- Asegurar la evidencia digital de acuerdo con guías departamentales. *Es importante destacar que esta guía reitera la necesidad de desarrollar SOPs –Standard Operating Procedures, procedimientos operativos estándares.*
- Documentar la configuración hardware y software del sistema empleado por el examinador.
- ...



Metodologías NIJ

Directrices para responsables de la 1ª respuesta 2/4

- Verificar la operación del sistema informático del examinador, que incluya hardware y software.
- Desmonta la caja del ordenador que se va a examinar para permitir acceso físico a los dispositivos de almacenamiento.
- Controlar que se asegura que el material está protegido de electricidad estática y campos magnéticos.
- ...



Metodologías NIJ

Directrices para responsables de la 1ª respuesta 3/4

- Identificar los dispositivos de almacenamiento que necesitan ser volcados. Estos dispositivos pueden ser internos, externos, o de ambos tipos.
- Documentar los dispositivos de almacenamiento y la configuración de hardware; incluyendo los parámetros del disco y los componentes internos.



Metodologías NIJ

Directrices para responsables de la 1ª respuesta 4/4

- Se desconectan los dispositivos de almacenamiento, usando el conector de energía y el cable de la parte trasera del dispositivo o de la placa madre, para prevenir la destrucción, el daño, o la alteración de los datos.



Metodologías NIJ

Directrices para analistas forenses 1/2

- Las acciones tomadas para asegurar y recoger la evidencia digital no debería afectar la integridad de esa evidencia.
- Las personas que realizan un análisis de evidencia digital deberían estar entrenadas para ese propósito.



Metodologías NIJ

Directrices para analistas forenses 2/2

- La actividad relativa a la incautación, examen, almacenamiento o transferencia de la evidencia digital debería ser documentada, preservada, y disponible para revisión.
- Durante todo este proceso, el examinador debería ser consciente de la necesidad de llevar el examen de la evidencia digital forma precisa e imparcial.

CONCLUSIÓN



Conclusión

Es posible cumplir estas metodologías de forma sencilla, siguiendo lo especificado en esta presentación